IDOR — Acceso no autorizado a la API key de otro usuario

1. Descripción

Se identificó una vulnerabilidad de control de acceso a nivel de objeto, conocida como IDOR (*Insecure Direct Object Reference*), en la funcionalidad de consulta de la cuenta de usuario.

La aplicación permite consultar información de una cuenta mediante el parámetro `id`. Al modificar el identificador de `wiener` a `carlos`, el servidor devuelve información de la cuenta de otro usuario, incluida su API key, sin verificar adecuadamente la autorización sobre el recurso solicitado.

2. Entorno y metodología

- Plataforma: PortSwigger Web Security Academy.
- Herramienta: Burp Suite Repeater.
- Tipo de prueba: evaluación de control de acceso horizontal.
- Entorno: laboratorio controlado y autorizado.

3. Evidencia

Evidencia 1 — Solicitud legítima

Se capturó la petición original utilizada para consultar la cuenta propia.

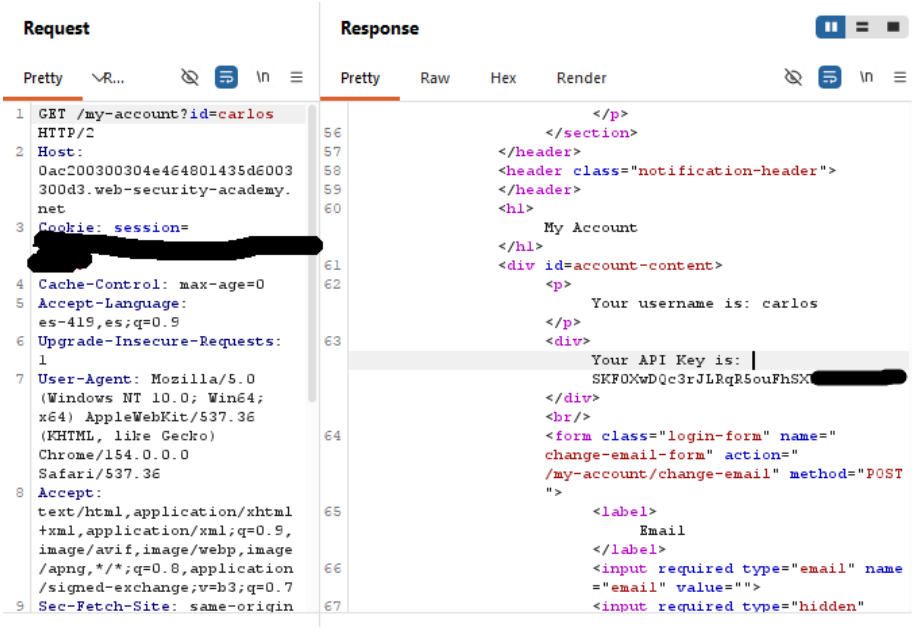
Archivo:



Evidencia 2 — Manipulación del identificador

Se modificó el parámetro `id` para solicitar la cuenta de otro usuario. La respuesta del servidor expuso la API key asociada a esa cuenta.

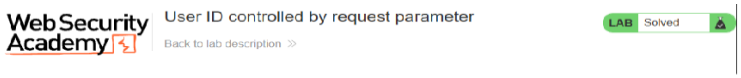
Archivo:



Evidencia 3 — Validación del laboratorio

PortSwigger confirmó que se completó el laboratorio.

Archivo:



4. Impacto

Confidencialidad: se confirmó el acceso no autorizado a información de otro usuario, incluida su API key.

Integridad: no se demostró modificación de información.

Disponibilidad: no se demostró afectación de la disponibilidad.

El impacto adicional de la API key depende de los permisos y recursos a los que permita acceder; no se presupone que pueda utilizarse para otras operaciones sin evidencia.

5. Causa raíz

La aplicación no aplica una comprobación de autorización adecuada sobre el objeto solicitado. El servidor utiliza el identificador proporcionado por el cliente sin verificar correctamente que el usuario autenticado tenga permiso para acceder a la cuenta correspondiente.

6. Remediación

- Implementar autorización del lado del servidor en cada solicitud que acceda a recursos de usuario.
- Vincular la consulta al usuario autenticado o comprobar explícitamente sus permisos sobre el objeto solicitado.
- No confiar en identificadores enviados por el cliente como mecanismo de autorización.
- Aplicar pruebas de seguridad que verifiquen el aislamiento entre cuentas.

7. Severidad y prioridad

Severidad estimada: Media, pendiente de valorar el alcance real de la API key.

CVSS orientativo: 6.5 (Medium), únicamente como estimación provisional bajo el supuesto de acceso remoto, baja complejidad, privilegios bajos, sin interacción adicional, alcance sin cambios e impacto alto en confidencialidad.

Vector provisional: `CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N`

La puntuación debe revisarse si la API key permite acciones adicionales o si el alcance del impacto es diferente.

8. Conclusión

La prueba demuestra una falla de autorización horizontal que permite acceder a información perteneciente a otro usuario mediante la manipulación de un identificador. La corrección debe aplicarse en el servidor, garantizando que cada usuario solo pueda acceder a los recursos para los que tiene autorización.